

HealthData Alliance BCR 审查报告草案

BCR-C 合规审查报告

审查对象：HealthData Alliance

审查范围：BCR Document-Driven Review (BCR-C)

审查日期：20260808

综合评级：高风险

关键发现

Binding nature (internal and external) 覆盖不完整；Third-party beneficiary rights 覆盖不完整；EU liable entity designation 覆盖不完整；Complaint handling mechanism 覆盖不完整；缺失 Cooperation with supervisory authorities

详细审查结果

检 查 项	主题	风 险	现状	整改建议	法律依据
BCR -C-1 .1	Binding nature (internal and external) 覆盖不完整	HIGH	Binding nature (internal and external) 部分覆盖但缺少关键要素. 依据：GDPR Article 47(1)(a), EDPB Recommendations 1/2022。证据：未提及集团内协议或其他具有法律约束力的内部文书	应补充 Binding nature (internal and external) 的完整内容。	GDPR Article 47(1)(a) [1]；EDPB Recommendations 1/2022
BCR -C-1 .2	Third-party beneficiary rights 覆盖不完整	HIGH	Third-party beneficiary rights 部分覆盖但缺少关键要素. 依据：GDPR Article 47(1)(b), EDPB Recommendations 1/2022。证据：文本未包含数据主体可直接强制执行 BCR 的第三方受益人权利描述	应补充 Third-party beneficiary rights 的完整内容。	GDPR Article 47(1)(b) [1]；EDPB Recommendations 1/2022

检 查 项	主题	风 险	现状	整改建议	法律依据
BCR -C-1 .3	EU liable entity designation 覆盖不完整	HIGH	EU liable entity designation 部分覆盖但 缺少关键要素. 依据：GDPR Article 47(2)(f), EDPB Recommendations 1/2022 。证据：未指定一个在 欧盟境内设立的实体作 为承担BCR合规责任的 主体	应补充 EU liable entity designation 的完整内容。	GDPR Article 47(2)(f) [1]；EDPB Recommendations 1/2022
BCR -C-1 .6	Complaint handling mechanism 覆盖不完整	MEDIUM	Complaint handling mechanism 部分覆盖但 缺少关键要素. 依据：GDPR Article 47(2)(e), EDPB Recommendations 1/2022 。证据：未明确投诉处 理的时限（如一个月内 ）	应补充 Complaint handling mechanism 的完整内容。	GDPR Article 47(2)(e)；EDPB Recommendations 1/2022
BCR -C-1 .7	缺失 Cooperation with supervisory authorities	MEDIUM	未在文档中找到 Cooperation with supervisory authorities 的相关内容. 依据：GDPR Article 47(2)(f), EDPB Recommendations 1/2022。证据：	应补充 Cooperation with supervisory authorities 的完整内容。	GDPR Article 47(2)(f)；EDPB Recommendations 1/2022
BCR -C-1 .8	Onward transfer restrictions 表述模糊	HIGH	Onward transfer restrictions 使用了模糊 表述，未达到具体可执 行标准. 依据：GDPR Chapter V, EDPB Recommendations 1/2022 。证据：使用'substantia lly similar'等笼统表述定 义保护标准，未指向具 体GDPR保护水平或SC C	应补充 Onward transfer restrictions 的完整内容。	GDPR Chapter V；EDPB Recommendations 1/2022

检 查 项	主题	风 险	现状	整改建议	法律依据
BCR -C-1 .9	Third country law assessment (TIA) 覆盖不完整	HIGH	Third country law assessment (TIA) 部分覆 盖但缺少关键要素. 依据：Schrems II, EDPB 01/2020, EDPB Recommendations 01/202 0。证据：未说明使用E DPB六步法或其他结构 化方法进行TIA	应补充 Third country law assessment (TIA) 的完整内容。	Schrems II, EDPB 01/2020 [2]；EDPB Recommendations 01/2020
BCR -C-1 .10	缺失 Audit and training mechanisms	MEDIUM	未在文档中找到 Audit and training mechanisms 的相关内容. 依据：GDPR Article 47(2)(h), EDPB Recommendations 1/2022。证据：	应补充 Audit and training mechanisms 的完整内容。	GDPR Article 47(2)(h)；EDPB Recommendations 1/2022
BCR -C-1 .12	Termination and exit provisions 覆盖不完整	MEDIUM	Termination and exit provisions 部分覆盖但缺 少关键要素. 依据：GDPR Article 47(2)(j), EDPB Recommendations 1/2022 。证据：命中关键词: ['end']	应补充 Termination and exit provisions 的完整内容。	GDPR Article 47(2)(j)；EDPB Recommendations 1/2022
BCR -SH ARE D-2	Personal data breach notification 覆盖不完整	MEDIUM	Personal data breach notification 部分覆盖但 缺少关键要素. 依据：， GDPR Article 33, 34。证据：命中关键词: ['breach']	应补充 Personal data breach notification 的完整内容。	；GDPR Article 33, 34
BCR -SH ARE D-3	Government access request handling 覆盖不完整	MEDIUM	Government access request handling 部分覆 盖但缺少关键要素. 依据：， EDPB Recommendations 01/2020, 1/2022。证据： 命中关键词: ['order']	应补充 Government access request handling 的完整内容。	；EDPB Recommendations 01/2020, 1/2022

检 查 项	主题	风 险	现状	整改建议	法律依据
BCR -C-1 .9	TIA 未引用 EDPB 结构化评估方法	ME DIU M	TIA 描述未引用 EDPB 01/2020 六步法或其他结构化评估方法。	建议按照 EDPB 01/2020 六步法进行第三国法律评估	Schrems II [2] ; EDPB Recommendations 01/2020
BCR -C-1 .9	TIA 缺少定期审查机制	ME DIU M	TIA 描述未说明评估的定期审查和更新频率。	应承诺至少每两年或在目标国法律发生重大变化时重新评估	Schrems II [2] ; EDPB Recommendations 01/2020
BCR -C-1 .9	TIA 未提及补充保护措施	ME DIU M	TIA 描述未说明在第三国保护水平不足时应采取的补充措施。	应说明当 TIA 识别出风险时, 将采取哪些补充技术、组织或合同措施	Schrems II [2] ; EDPB Recommendations 01/2020
BCR -C-1 .9	TIA 缺少无法缓解风险时的中止条款	ME DIU M	TIA 描述未说明当风险无法通过补充措施缓解时, 将暂停或中止数据传输。	应明确承诺当无法确保实质等同保护水平时, 将暂停相关数据传输	Schrems II [2] ; EDPB Recommendations 01/2020
BCR -C-1 .8	未明确限制向非 BCR 成员传输	ME DIU M	BCR 文档未明确限制向非 BCR 成员或集团外第三方的数据传输。	应增加明确条款, 限制向非 BCR 成员传输数据, 除非有合法依据和保护措施	GDPR Chapter V ; EDPB Recommendations 1/2022
BCR -C-1 .8	缺少转委托授权机制	ME DIU M	未说明向第三方传输是否需要事先书面授权或预先批准。	建议增加转委托的授权机制	GDPR Chapter V ; EDPB Recommendations 1/2022
BCR -C-1 .3	未明确指定 EU 责任主体	HIG H	BCR 文档未明确指定一个在欧盟境内设立的实体作为承担合规责任的 liability entity。	必须指定一个欧盟实体, 接受对非欧盟成员违反 BCR 的责任并承担赔偿责任	GDPR Article 47(1)(b), 47(2)(f) [1] ; EDPB Recommendations 1/2022
BCR -C-1 .3	EU 责任主体未明确承诺责任/赔偿	ME DIU M	未说明 EU 责任主体是否接受对非欧盟成员违规行为的法律责任和赔偿责任。	应明确 EU 责任主体将对非欧盟成员的 BCR 违规行为承担赔偿责任	GDPR Article 47(1)(b), 47(2)(f) [1] ; EDPB Recommendations 1/2022
BCR -C-1 .3	未赋予数据主体第三方受益人权利	HIG H	BCR 文档未明确赋予数据主体第三方受益人权利以直接强制执行 BCR。	应增加独立条款, 明确数据主体作为第三方受益人有权强制执行 BCR 条款	GDPR Article 47(1)(b), 47(2)(f) [1] ; EDPB Recommendations 1/2022
BCR -C-1 .3	缺少数据主体救济渠道说明	ME DIU M	BCR 文档未说明数据主体可获得的有效救济渠道 (司法或行政)。	应说明数据主体可获得的有效救济渠道	GDPR Article 47(1)(b), 47(2)(f) [1] ; EDPB Recommendations 1/2022

检 查 项	主题	风 险	现状	整改建议	法律依据
BCR -C-1 .1	转委托处理缺乏书面授权机制	HIGH	未要求子处理者转委托须经事先书面授权	建议要求所有转委托须经事先书面授权	GDPR (EU) 2016/679 第段落1条 [1]；GDPR (EU) 2016/679 第段落2条
BCR -C-1 .1	TIA 评估方法不够完整	MEDIUM	TIA 描述未涵盖EDPB六步法或周期性审查	建议涵盖EDPB六步法、周期性审查、补充措施和当地法律实践评估	GDPR (EU) 2016/679 第段落1条 [1]；GDPR (EU) 2016/679 第段落2条
BCR -C-1 .1	投诉处理时限未明确	MEDIUM	投诉处理条款未明确响应和处理时限	建议明确承诺在一个月 内响应和调查投诉	GDPR (EU) 2016/679 第段落1条 [1]；GDPR (EU) 2016/679 第段落2条
BCR -C-1 .1	缺少法律约束力文书 具体说明	HIGH	未提及集团内协议或其他具有法律约束力的内部文书	应说明BCR通过何种法律 文书对所有成员产生约束力	GDPR (EU) 2016/679 第段落1条 [1]；GDPR (EU) 2016/679 第段落2条
BCR -C-1 .1	缺少子处理者变更通知机制	MEDIUM	未说明子处理者变更时是否通知控制者	应明确承诺在子处理者 变更前通知控制者并给 予反对机会	GDPR (EU) 2016/679 第段落1条 [1]；GDPR (EU) 2016/679 第段落2条

高风险项目

Binding nature (internal and external) 覆盖不完整；Third-party beneficiary rights 覆盖不完整；EU liable entity designation 覆盖不完整；Onward transfer restrictions 表述模糊；Third country law assessment (TIA) 覆盖不完整；未明确指定 EU 责任主体；未赋予数据主体第三方受益人权利；转委托处理缺乏书面授权机制；缺少法律约束力文书具体说明

中风险项目

Complaint handling mechanism 覆盖不完整；缺失 Cooperation with supervisory authorities；缺失 Audit and training mechanisms；Termination and exit provisions 覆盖不完整；Personal data breach notification 覆盖不完整；Government access request handling 覆盖不完整；TIA 未引用 EDPB 结构化评估方法；TIA 缺少定期审查机制；TIA 未提及补充保护措施；TIA 缺少无法缓解风险时的中止条款；未明确限制向非 BCR 成员传输；缺少转委托授权机制；EU 责任主体未明确承诺责任/赔偿；缺少数据主体救济渠道说明；TIA 评估方法不够完整；投诉处理时限未明确；缺少子处理者变更通知机制

低风险项目

无

整改路线图

高风险项（需立即整改）：

- Binding nature (internal and external) 覆盖不完整
- Third-party beneficiary rights 覆盖不完整
- EU liable entity designation 覆盖不完整
- Onward transfer restrictions 表述模糊
- Third country law assessment (TIA) 覆盖不完整

可直接采用的建议条款

- BCR-C-1.1 Binding nature (internal and external) 覆盖不完整：These Binding Corporate Rules constitute a legally binding instrument that is enforceable by all BCR members against each other and by data subjects as third-party beneficiaries. Each BCR member shall enter into an intra-group agreement that expressly incorporates these Rules and creates binding obligations under the law of [EU Member State].
- BCR-C-1.2 Third-party beneficiary rights 覆盖不完整：Data subjects shall have the right to enforce these Rules as third-party beneficiaries against the EU liable entity and any BCR member. This right includes: (a) the right to lodge a complaint with the competent supervisory authority; (b) the right to an effective judicial remedy; and (c) the right to claim compensation for damages suffered as a result of a breach of these Rules.
- BCR-C-1.3 EU liable entity designation 覆盖不完整：[Company Name], established in [EU Member State], shall act as the EU liable entity and shall: (a) accept responsibility for and guarantee compliance with these Rules by all BCR members; (b) assume the burden of proof that a BCR member has not violated these Rules; (c) maintain sufficient assets within the EU to meet any compensation claims by data subjects.
- BCR-C-1.8 Onward transfer restrictions 表述模糊：[Insert specific clause addressing the identified requirement in accordance with GDPR Article 47 and EDPB Recommendations]
- BCR-C-1.9 Third country law assessment (TIA) 覆盖不完整：[Insert specific clause addressing the identified requirement in accordance with GDPR Article 47 and EDPB Recommendations]
- BCR-C-1.3 未明确指定 EU 责任主体：[Company Name], established in [EU Member State], shall act as the EU liable entity and shall: (a) accept responsibility for and guarantee compliance with these Rules by all BCR members; (b) assume the burden of proof that a BCR member has not violated these Rules; (c) maintain sufficient assets within the EU to meet any compensation claims by data subjects.
- BCR-C-1.3 未赋予数据主体第三方受益人权利：[Company Name], established in [EU Member State], shall act as the EU liable entity and shall: (a) accept responsibility for and guarantee compliance with these Rules by all BCR members; (b) assume the burden of proof that a BCR member has not violated these Rules; (c) maintain sufficient assets within the EU to meet any compensation claims by data subjects.
- BCR-C-1.1 转委托处理缺乏书面授权机制：These Binding Corporate Rules constitute a legally binding instrument that is enforceable by all BCR members against each other and by data subjects as third-party beneficiaries. Each BCR member shall enter into an intra-group agreement that expressly incorporates these Rules and creates binding obligations under the law of [EU Member State].
- BCR-C-1.1 缺少法律约束力文书具体说明：These Binding Corporate Rules constitute a legally binding instrument that is enforceable by all BCR members against each other and by data subjects as third-party beneficiaries. Each BCR member shall enter into an intra-group agreement that expressly incorporates these Rules and creates binding obligations under the law of [EU Member State].